

ĐẶC TẢ YÊU CẦU HỆ THỐNG (SRS)

Viện Sau Đại học – Trường Đại học Văn Lang

Mã tài liệu	SRS
Phiên bản	v0.1
Trạng thái	Draft
Ngày lập	2026-09-04
Người phê duyệt	Cần xác nhận
Phân loại nguồn	Xác nhận tài liệu / Quan sát hệ thống / Đề xuất BA / Cần xác nhận

Lưu ý: Tài liệu không chứa mật khẩu, token, khóa API hoặc dữ liệu cá nhân không cần thiết.

Kiểm soát tài liệu

Phiên bản	Ngày	Trạng thái	Thay đổi	Phê duyệt
v0.1	2026-09-04	Draft	Khởi tạo từ khảo sát repository và giao diện/mã nguồn	Cần xác nhận

Nguồn tham chiếu

Mã	Loại	Nguồn	Mục đích
SRC-01	Tài liệu	README.md	Tổng quan, cấu trúc, vai trò và hướng dẫn chạy
SRC-02	Tài liệu	PROJECT_CONTEXT.md	Kiến trúc, route, module và mô hình dữ liệu
SRC-03	Tài liệu	docs/handover/*	Triển khai, bảo mật, sao lưu, vận hành; các tuyên bố nghiệm thu chưa có minh chứng được đánh dấu cần xác nhận
SRC-04	Mã nguồn	backend/prisma/schema.prisma	Mô hình dữ liệu và enum quan sát được
SRC-05	Mã nguồn	backend/src/modules/*	API, validation, RBAC và luồng xử lý quan sát được
SRC-06	Mã nguồn	admin/src/app và admin/src/components	Màn hình quản trị, trình soạn thảo, upload, phân quyền quan sát được
SRC-07	Mã nguồn/Giao diện	frontend/src/app và frontend/src/features	Trang công khai, biểu mẫu, song ngữ và điều hướng quan sát được
SRC-08	Cấu hình công khai	package.json, compose.yaml, *.env.example	Phụ thuộc kỹ thuật; không đọc giá trị bí mật trong .env

1. Phạm vi và nguyên tắc

SRS này mô tả yêu cầu có thể kiểm thử cho bản Draft. Workbook REQ là nguồn quản lý chi tiết; tài liệu này không lập toàn bộ bảng mà tham chiếu theo Requirement ID.

2. Role và phân quyền

Mã	Role	Public	Dashboard	Tin	Tài nguyên	Tư vấn	Nhân sự/Audit
ROL-01	Khách truy cập	Xem/Gửi	Không	Chỉ PUBLISHED	Chỉ PUBLISHED	Tạo mới	Không
ROL-02	QTV Cấp 2	Xem	Có	CRUD theo quyền	CRUD theo quyền	Xem/Cập nhật	Không
ROL-03	Super Admin	Xem	Có	CRUD	CRUD	Xem/Cập nhật	Toàn quyền

Lưu ý: quyền được enforcement phía server bằng mã permission. Chi tiết mapping từng permission cần lấy từ bootstrap/DB môi trường và xác nhận trước UAT.

3. Quy trình nghiệp vụ

3.1 Hiện trạng

Không có tài liệu AS-IS về quy trình thủ công trước hệ thống. Cần xác nhận với stakeholder; không suy diễn từ code.

3.2 Quy trình đề xuất/quan sát được

- Xuất bản tin: đăng nhập → tạo/nhập nội dung → upload ảnh → lưu Draft → kiểm tra → chuyển Published → hiển thị công khai. Bước phê duyệt độc lập là đề xuất BA, chưa có trong code.
- Tư vấn: khách gửi biểu mẫu → hệ thống validation/rate-limit → tạo NEW → cán bộ xem/phân công → cập nhật trạng thái/ghi chú → đóng. Ma trận chuyển trạng thái và SLA TBD.
- Tài nguyên: cán bộ upload tệp + metadata → chọn danh mục/trạng thái → công bố → khách tra cứu/tải. Chính sách xóa/retention TBD.

4. Danh mục yêu cầu chức năng

Cổng công khai

ID	Tên	Yêu cầu	Nguồn/Trạng thái
PUB-001	Xem trang song ngữ	Hệ thống phải cung cấp tuyến /vi và /en và duy trì locale khi điều hướng.	Quan sát — SRC-02,SRC-07
PUB-002	Tra cứu chương trình	Hệ thống phải hiển thị danh mục chương trình và hỗ trợ tìm/lọc theo dữ liệu hiện có.	Quan sát — SRC-02,SRC-07
PUB-003	Xem tin đã xuất bản	API công khai chỉ được trả tin trạng thái PUBLISHED và đúng điều kiện thời gian công bố.	Quan sát — SRC-02,SRC-05,SRC-07
PUB-004	Tải tài nguyên công khai	Hệ thống phải liệt kê tài nguyên công khai và phân phối tệp qua proxy nội bộ.	Quan sát — SRC-02,SRC-05,SRC-07

Dashboard

ID	Tên	Yêu cầu	Nguồn/Trạng thái
DASH-001	Xem số liệu tổng hợp	Người có dashboard.view phải xem được số liệu tổng hợp theo dữ liệu hệ thống.	Quan sát — SRC-02,SRC-05,SRC-06

Hồ sơ ứng tuyển

ID	Tên	Yêu cầu	Nguồn/Trạng thái
APP-001	Xem hồ sơ ứng tuyển	Người có quyền phù hợp phải xem danh sách Application và trạng thái.	Quan sát — SRC-02,SRC-04,SR C-05,SRC-06

Nhân sự

ID	Tên	Yêu cầu	Nguồn/Trạng thái
USR-001	Quản lý tài khoản	Chỉ SUPER_ADMIN hoặc quyền admins.* tương ứng được thao tác tài khoản.	Đã xác nhận + Quan sát — SRC -01,SRC-02,SRC-05,SRC-06

Nhật ký

ID	Tên	Yêu cầu	Nguồn/Trạng thái
AUD-001	Tra cứu nhật ký	Hệ thống phải ghi và cho phép truy xuất audit theo quyền đối với các hành động được định nghĩa.	Quan sát một phần — SRC-02,SRC-04,SRC-05

Nội dung website

ID	Tên	Yêu cầu	Nguồn/Trạng thái
SITE-001	Cập nhật khối nội dung	Người có quyền phù hợp phải upsert SiteContent theo key duy nhất và cờ published.	Quan sát — SRC-04,SRC-05,SRC-06

Tin tức

ID	Tên	Yêu cầu	Nguồn/Trạng thái
NEWS-001	Tạo tin nhập	Người có news.create phải tạo được bài với tiêu đề, slug, locale, danh mục và nội dung hợp lệ.	Quan sát — SRC-05,SRC-06
NEWS-002	Soạn nội dung định dạng	Trình soạn thảo phải hỗ trợ định dạng cho phép và làm sạch HTML trước khi lưu/hiển thị.	Quan sát — SRC-05,SRC-06
NEWS-003	Tải ảnh bài viết	Hệ thống phải nhận JPG/PNG/WebP/AVIF tối đa 8 MB và lưu trong kho đối tượng.	Quan sát — SRC-05,SRC-06
NEWS-004	Xuất bản tin	Người có news.update phải chuyển bài sang PUBLISHED và thiết lập thời điểm công bố hợp lệ.	Quan sát — SRC-05,SRC-06
NEWS-005	Lưu trữ tin	Thao tác xóa tin phải chuyển trạng thái ARCHIVED và ghi audit.	Quan sát — SRC-05

Tài nguyên

ID	Tên	Yêu cầu	Nguồn/Trạng thái
RES-001	Tạo và tải tài nguyên	Người có resources.create phải tải tệp được phép và tạo bản ghi gắn danh mục.	Quan sát — SRC-05,SRC-06
RES-002	Quản lý danh mục tài nguyên	Hệ thống phải bảo toàn ràng buộc khi danh mục còn tài nguyên tham chiếu.	Quan sát — SRC-05
RES-003	Xóa tài nguyên	Người có resources.delete có thể xóa bản ghi tài nguyên; tác động lên tệp vật lý phải được xác định.	Quan sát/Cần xác nhận — SRC-05

Tư vấn

ID	Tên	Yêu cầu	Nguồn/Trạng thái
CON-001	Gửi yêu cầu tư vấn	Hệ thống phải kiểm tra dữ liệu bắt buộc, chống bot cơ bản và ghi nhận yêu cầu tư vấn.	Quan sát — SRC-02,SRC-05,SRC-07
CON-002	Danh sách tư vấn	Người có consultations.view phải xem danh sách theo bộ lọc/phân trang được hỗ trợ.	Quan sát — SRC-05,SRC-06
CON-003	Cập nhật trạng thái tư vấn	Người có consultations.update phải chuyển trạng thái hợp lệ và ghi lịch sử.	Quan sát — SRC-04,SRC-05

Xác thực

ID	Tên	Yêu cầu	Nguồn/Trạng thái
AUTH-001	Đăng nhập quản trị	Hệ thống phải xác thực tài khoản, trạng thái và tạo phiên bằng cookie HttpOnly.	Quan sát — SRC-02,SRC-05,SRC-06
AUTH-002	Đổi mật khẩu bắt buộc	Hệ thống phải buộc đổi mật khẩu khi mustChangePassword=true và vô hiệu hóa phiên phù hợp sau thay đổi.	Quan sát — SRC-02,SRC-04,SRC-06

5. Business Rules

ID	Tên	Quy tắc
BR-01	Locale hỗ trợ	Locale quan sát: vi/en; fallback và mức độ dịch đầy đủ cần xác nhận.
BR-02	Nguồn chương trình	Danh mục chương trình hiện quan sát là dữ liệu tĩnh; ownership cập nhật cần xác nhận.
BR-03	Công bố tin	Chỉ PUBLISHED và thời điểm công bố hợp lệ được hiển thị công khai.
BR-04	Công bố tài nguyên	Chỉ tài nguyên đã công bố và tệp tồn tại được tải công khai.
BR-05	Dữ liệu tư vấn	Thông tin liên hệ phải được validation, rate-limit và xử lý theo chính sách dữ liệu được duyệt.
BR-06	Phiên quản trị	Phiên dùng token opaque băm, cookie HttpOnly; tài khoản không ACTIVE không được đăng nhập.
BR-07	Mật khẩu ban đầu	Tài khoản có mustChangePassword phải đổi mật khẩu.
BR-08	Slug tin	Slug là duy nhất; dữ liệu tin phải qua validation.
BR-09	HTML an toàn	Chỉ giữ tag/style/schema URL cho phép; loại script/nội dung nguy hiểm.
BR-10	Ảnh CMS	JPG/PNG/WebP/AVIF, tối đa 8 MB theo route upload quan sát.
BR-11	Lưu trữ tin	Xóa tin là chuyển ARCHIVED theo hành vi quan sát.
BR-12	Tệp tài nguyên	Cho phép PDF/Word/Excel/JPEG/PNG; ngưỡng dung lượng hiện mẫu thuẫn 25/50 MB.
BR-13	Danh mục tham chiếu	Không xóa danh mục còn tài nguyên tham chiếu.
BR-14	Xóa tài nguyên	Code quan sát xóa cứng bản ghi; retention/object cleanup cần quyết định.
BR-15	Quyền xem tư vấn	Cần consultations.view; phạm vi theo assignee chưa được xác nhận.
BR-16	Trạng thái tư vấn	Enum gồm NEW, RECEIVED, CONTACTING, CONSULTED, COMPLETED, UNREACHABLE, CANCELLED; transition matrix TBD.
BR-17	Quản trị nhân sự	QTV Cấp 2 không có quyền nhân sự; Super Admin có quyền theo tài liệu.
BR-18	KPI dashboard	Cách tính và kỳ báo cáo phải được business owner duyệt.
BR-19	SiteContent	Key duy nhất; nội dung công khai phụ thuộc cờ published.
BR-20	Hồ sơ ứng tuyển	Quy trình nguồn vào/xử lý/chủ sở hữu chưa được xác nhận.
BR-21	Audit	Không ghi secret; phạm vi sự kiện dựa trên enum và xử lý hiện có.
BR-22	Kiểm soát an toàn	RBAC server-side, rate limit, CORS, Argon2id, sanitization.
BR-23	BCP/DR	RPO/RTO, retention, nơi lưu và lịch diễn tập = TBD.
BR-24	Accessibility	Mục tiêu đề xuất WCAG 2.1 AA; cần stakeholder phê duyệt.

ID	Tên	Quy tắc
BR-25	SLO	Ngưỡng hiệu năng/uptime/MTTR = TBD.

6. Yêu cầu dữ liệu và tích hợp

Đối tượng	Dữ liệu chính	Validation/quan hệ	Nguồn
Admin	username, fullName, email, phone, role, status	username duy nhất; role bắt buộc; secret chỉ lưu dạng hash	SRC-04
NewsPost	slug, locale, title, category, content, coverImage, status, author	slug duy nhất; author bắt buộc; HTML sanitize	SRC-04,SRC-05
ResourceFile	slug, title, category, loại, metadata văn bản, URL/tên/loại/kích thước tệp, status	category bắt buộc; file metadata bắt buộc; FK restrict	SRC-04,SRC-05
Consultation	thông tin liên hệ, nhu cầu, lịch, phương thức, trạng thái, assignee	validation + rate limit; lịch sử/ghi chú	SRC-04,SRC-05
Application	họ tên, email, phone, programme, status, metadata	Quy trình và validation nghiệp vụ TBD	SRC-04
PageVisit	path, locale, visitorId, thời gian	best-effort; retention TBD	SRC-04,SRC-07
Tích hợp	PostgreSQL, MinIO; Redis/SMTP/CRM tùy chọn	Endpoint/credential qua môi trường; không ghi secret	SRC-03,SRC-08

7. Yêu cầu phi chức năng

ID	Yêu cầu	Ngưỡng/AC
NFR-001	Hệ thống phải áp dụng RBAC phía server, cookie HttpOnly, bấm mật khẩu, CORS giới hạn, rate limit và làm sạch HTML.	Given request nhảy cảm không phiên/quyền When gọi Then 401/403; Given HTML độc hại When lưu Then bị làm sạch; Given lỗi Then không lộ secret/stack trong production.
NFR-002	Phải có quy trình sao lưu PostgreSQL và MinIO, mã hóa/phân quyền bản sao và diễn tập phục hồi định kỳ.	Given lịch sao lưu được duyệt When đến kỳ Then tạo bản sao và log; Given yêu cầu phục hồi When thực hiện Then đối soát DB-tệp; RPO/RTO và chu kỳ lưu giữ = TBD.
NFR-003	Các luồng trọng yếu phải đáp ứng WCAG 2.1 AA hoặc chuẩn được stakeholder phê duyệt.	Given điều hướng bàn phím When dùng trang Then focus rõ và thao tác được; Given ảnh nội dung When hiển thị Then có alt phù hợp; ngưỡng kiểm tra chính thức = TBD.
NFR-004	Phải thống nhất SLO cho thời gian đáp ứng, tải đồng thời, uptime và cảnh báo trước nghiệm thu.	Given kịch bản tải đã duyệt When kiểm thử Then đáp ứng ngưỡng TBD; Given phụ thuộc lỗi When truy cập Then suy giảm an toàn; uptime/MTTR = TBD.

8. Use Case trọng yếu

UC-01 — Đăng và xuất bản tin

Tác nhân	ROL-02/03
Điều kiện trước	Có phiên và news.create/update
Điều kiện sau	Tin được lưu; nếu Published thì đủ điều kiện công khai
Luồng chính	1. Mở CMS tin. 2. Nhập metadata/nội dung. 3. Upload ảnh. 4. Lưu Draft. 5. Chuyển Published.
Thay thế/ngoại lệ	Slug trùng; file sai; HTML nguy hiểm; lỗi kho tệp; không quyền → báo lỗi/401/403 và không công bố sai.
Yêu cầu liên quan	NEWS-001..004

UC-02 — Gửi và xử lý tư vấn

Tác nhân	ROL-01, ROL-02/03
Điều kiện trước	Trang công khai hoạt động; cán bộ có quyền
Điều kiện sau	Lead có lịch sử trạng thái; dữ liệu bảo toàn
Luồng chính	1. Khách nhập form. 2. Validation/rate-limit. 3. Tạo NEW. 4. Cán bộ mở, phân công, cập nhật.
Thay thế/ngoại lệ	Dữ liệu sai; bot/rate limit; trạng thái sai; không quyền; lead không tồn tại.
Yêu cầu liên quan	CON-001..003

UC-03 — Đăng và tải tài nguyên

Tác nhân	ROL-02/03, ROL-01
Điều kiện trước	Danh mục tồn tại; cán bộ có quyền
Điều kiện sau	Bản ghi/tệp lưu; tài nguyên công bố tải được
Luồng chính	1. Upload tệp. 2. Nhập metadata/danh mục. 3. Công bố. 4. Khách lọc/tải.
Thay thế/ngoại lệ	Tệp sai/quá lớn; MinIO lỗi; danh mục sai; không quyền; tệp mất.
Yêu cầu liên quan	RES-001..003,PUB-004

UC-04 — Quản lý tài khoản

Tác nhân	ROL-03
Điều kiện trước	Super Admin có phiên/quyền
Điều kiện sau	Tài khoản thay đổi và có audit
Luồng chính	1. Mở nhân sự. 2. Tạo/sửa role/trạng thái. 3. Cấp mật khẩu tạm. 4. Người dùng đổi mật khẩu.
Thay thế/ngoại lệ	Username trùng; role sai; tự khóa tài khoản cuối cùng; QTV cấp 2 truy cập.
Yêu cầu liên quan	USR-001,AUTH-002

9. Glossary

Thuật ngữ	Giải thích
CMS	Hệ thống quản trị nội dung.
CRM	Quản lý quan hệ/nhu cầu tư vấn của người quan tâm.
RBAC	Kiểm soát truy cập theo vai trò và permission.
UAT	Kiểm thử chấp nhận của người dùng nghiệp vụ.
RPO/RTO	Mức mất dữ liệu tối đa chấp nhận được / thời gian phục hồi mục tiêu.
SLO	Mục tiêu mức dịch vụ.
MinIO	Kho lưu trữ đối tượng tương thích S3, có thể tự vận hành.
TBD	Chưa xác định, cần quyết định.